**Vulnerability Assessment Report**

## 1. Introduction

This report presents a security analysis of a mobile application's client-side JavaScript bundle and related resources. The objective is to identify vulnerabilities that may expose sensitive information, weaken system security controls, or allow unauthorized access. The findings are based on static analysis of the provided artifacts.

## 2. Methodology

1. **Static artifact inspection:** Reviewed the provided bundles and embedded configuration-like structures.
2. **Sensitive data identification:** Searched for indicators of:
    - API keys / client secrets
    - private keys / cryptographic material
    - authentication/verification values
    - card/payment-related data
    - access tokens and authorization headers
    - sensitive values in console/logging and network headers
    - permissive CORS/origin settings
3. **Vulnerability grouping:** Consolidated observations into security vulnerability categories based on insecure client-side handling patterns and exposure points.
4. **Evidence capture:** Included the exact evidence snippets you provided in the analysis text and extracted from the uploaded artifacts where available.
5. **OWASP mapping: Excluded**, as requested.

---

## 3. Vulnerability Findings

Table format: **Vulnerability | Sensitive data | Evidence (full snippet) | Impact | Fix**

| Vulnerability | **Sensitive data** | **Evidence (full snippet)** | **Impact** | **Fix** |
|---|---|---|---|---|
| Hardcoded API Key in Request Headers (Critical) | apikey | js\nheaders:{\n apikey:\"eQEA26ZYAb3ng5Ap7QAc4qQQQ0zOpXLP\",\n \"Content-Type\":\"application/json\"\n}\n | Unauthorized API access; abuse of backend services; potential data breaches | Remove API keys from frontend; store and manage keys on backend; use authenticated API gateway and short-lived credentials |
| Hardcoded API Keys (Critical) | API keys embedded in client code | js\napikey:\"eQEA26ZYAb3ng5Ap7QAc4qQQQ0zOpXLP\"\napikey:\"11d9fSFdTkAzxfgQTCrQGoU6Fym7gp6CwbtO8tIiHATw2wjk\"\n'x-apikey':'t19Mi6U6MLwkM1KhG2Uq0czwyAA56BTYTzIhx131IbOMItaZ'\n | Unauthorized API usage and service abuse | Move keys to server-side only; use per-user auth tokens; rotate keys |
| Hardcoded API Key Added to Header via xhr (Critical) | apiKey | js\nxhr.setRequestHeader(\"apiKey\",\"Ljez48Xr7oUHpvxOUB2Z1QdiewGrMp3j\")\n | Key extraction and replay; direct API misuse | Do not send long-term keys from client; use backend-mediated calls |

| | | | | |
|---|---|---|---|---|
| Hardcoded Credentials / Secrets (Critical) | secret | js\nsecret:'tcs#123'\n | Compromise authentication/crypto flow; reverse engineering enables bypass | Remove secrets from client; use secure server-side secret management |
| Hardcoded Credentials / Secrets (Critical) | nsdlDmzUserName, nsdlDmzPassword | js\nnsdlDmzUserName:\"j7UluUAZmZN2zZ3JQsJvr4XKBimn7Zwj\"\nnsdlTokenClientSecret:\"YxBtTz4N6KE0xXRg\"\n | Credential compromise of dependent services | Store credentials only on server; rotate exposed values |
| Private Key Exposure (Critical) | Private keys in files | plaintext\n-----BEGIN PRIVATE KEY-----\nMIIJQwIBADANBgkqhkiG9w0BAQEFAASCCS0...\n-----END PRIVATE KEY-----\n | Catastrophic crypto compromise | Private keys must never ship with client apps; store in HSM/keystore on backend |
| Private Key Exposure (Critical) | Private key PEM files | ```plaintext\nPayload\iMobile.app\Frameworks\IMBDFFKit.framework\Resources.bundle\private-key-production.pem:\n-----BEGIN PRIVATE KEY-----\nMIIJKQIBAAKCAgEAtkwjVTI4YNFbUW9j495OWgVaEAHTyy0TJ2kglPFQvoghM9On\n...\n-----END | | |